



Day 50



“CLOUD SECURITY”

Cloud Penetration Testing:

Cloud Penetration Testing is the process of assessing the security posture of cloud environments by identifying vulnerabilities in apps, servers, databases, networks, and configurations. It ensures confidentiality, integrity, and compliance by detecting flaws caused by shared resources, misconfigurations, or weak policies. Regular pen tests help organizations comply with standards, avoid legal issues, and uncover insider threats or insecure setups.

The most effective method is black-box testing, where the tester has no prior knowledge of the cloud setup. Pen testing can be manual (industry techniques) or automated using tools like *Core CloudInspect*, *CloudPassage Halo*, *Alert Logic*, and *SecludIT*.

Scope of Cloud Penetration Testing:

The scope of cloud penetration testing must be carefully defined due to the shared responsibility model, multi-tenant environments, and dynamic cloud resources. Testers should set scope based on the contracting party, deployment model, service model, technologies, and SLA to avoid testing unauthorized resources.

The scope typically includes three segments:

- App/Web Service Penetration Testing – Assess applications and services for vulnerabilities and weaknesses in how users access and interact with the cloud.
- Network Penetration Testing – Evaluate CSP networks (databases, firewalls, servers) and client networks (end systems, routers) for security gaps.
- Cloud Penetration Testing – Test virtual machines, apps, and operating systems in the cloud for risks unique to cloud environments.

Identify the type of cloud to be tested:

Before conducting penetration testing, testers must determine whether the target company is a cloud provider, tenant, or both, as this defines the scope. The type of cloud service model directly impacts what can be tested:

- IaaS (Infrastructure as a Service): Provider manages hardware and networking; tenant manages VMs and everything inside them (e.g., AWS, Rackspace).
- PaaS (Platform as a Service): Provider supplies the platform; tenant deploys and manages their applications (e.g., Microsoft Azure, CloudBees).
- SaaS (Software as a Service): Provider delivers the full application and infrastructure; tenant only uses the app (e.g., Salesforce, Mailchimp).

Identify what is to be tested in the Cloud Environment:

It will be mentioned there in scoping or engagement letter.

Identify tools for penetration testing:

For cloud penetration testing, testers can use both on-premises tools (installed locally for full control) and cloud-based tools (scalable and cost-effective). On-premises tools are traditional and customizable, while cloud-based tools are easier to deploy, more flexible, and often cheaper.

Cloud Reconnaissance Checklist

- Public resources – list exposed IPs, endpoints, buckets.
- IAM & permissions – check users, roles, policies (look for *).
- Security groups / ACLs – find open ports or wide CIDRs (0.0.0.0/0).
- Routing & subnets – public vs private exposure.
- Instances & services – outdated VMs, open SSH/RDP, metadata exposure.
- Storage & DBs – public read/write buckets, exposed DB endpoints.
- Serverless / APIs – insecure triggers, over-permissioned roles.
- Logging / monitoring – gaps in visibility.

Check for Lock-in Problems:

1. Lock-in = customer can't switch to another CSP easily.
2. Can severely impact business if CSP stops service.
3. Happens due to incompatible OS, configs, or resources.
4. Leads to high switching costs and migration challenges.
5. Clients should ensure flexibility to move between CSPs.
6. Testers must review SLA/contract terms for lock-in provisions.

Check for Governance Issues:

1. Verify roles & responsibilities of CSP vs. subscriber for infra, data, and security.
2. Look for discrepancies in SLA clauses and their enforcement.
3. Check CSP's audit, certification, and vulnerability assessment visibility.
4. Identify hidden dependencies on external resources.
5. Ensure transparency in tech standards and data storage jurisdictions.
6. Confirm presence of a source escrow agreement.
7. Review jurisdiction/legal coverage for SLA disputes.
8. Assess completeness, transparency, and asset ownership terms.

Check for Compliance Issues:

1. Ensure CSP follows regional laws & international standards (e.g., PCI, SOX).
2. Verify CSP conducts regular audits & tests (check SLA).
3. Confirm roles of CSP vs. client in compliance responsibilities.
4. Privacy compliance → sensitive data protected as per local laws & SLA.
5. Geographical compliance → CSP meets data norms of all operating countries.
6. Industry compliance → CSP supports sector-specific standards (banking, healthcare, etc.).

Check for Right Implementation of Security Management:

1. Ensure regular audits, scans, and checks for vulnerabilities, updates, and misconfigurations.
2. Verify skilled employees with knowledge of cloud security, authentication, and authorization.

3. Check if policies/procedures exist for system settings, network, access, remote use, and physical security.
4. Confirm strict policies for employees, devices, emails, and software.
5. Ensure risk assessment & mitigation processes (vulnerability assessment, risk capture, etc.).
6. Verify incident handling, backup, and disaster recovery mechanisms.
7. Check for idle resources reserved for business continuity.

Check the Cloud for Resource Isolation:

1. Verify tenant isolation – ensure one client’s activity doesn’t affect others (performance, bandwidth, scaling).
2. Analyze logs & service quality – check for drops, slow connections, or interruptions during peak hours.
3. Review client feedback & expert reviews – identify complaints about service or resource conflicts.
4. Check CSP track record – past issues or security incidents related to resource isolation.

Check Anti-Malware on Cloud Components:

1. Ensure all cloud components—data centers, servers, devices, access points, apps, databases, and suppliers—are protected with appropriate security controls.
2. Verify anti-malware applications are installed on every device and kept up-to-date with automatic updates.
3. Monitor for outbreak alerts, malware scans, and customized threats.
4. Use audit reports or manual checks to confirm coverage and effectiveness.

Check Firewalls at Network Entry Points:

1. Ensure firewalls are installed at every network entry point for cloud services.
2. Verify firewall effectiveness in blocking malicious traffic and logging events.
3. Review firewall policies: type, update schedule, rules, and access control.
4. Check alert mechanisms and how the organization handles firewall alerts/reports.
5. Ensure unused ports, protocols, and services are blocked and firewall is up-to-date.

Check Strong Authentication for Remote Users:

1. Ensure strong password policy (minimum 8 alphanumeric characters).
2. Implement two-factor authentication (2FA) for all remote users.
3. Use PKI key pairs to encrypt data and encrypted channels (SSH, VPN).
4. Apply MAC/IP filtering and deny insecure protocols like Telnet.
5. Verify that the authentication policy is properly implemented and enforced.

Check SSL Certificates for Cloud Services:

1. TLS/SSL Encryption – Ensure cloud services use HTTPS with valid SSL certificates to secure data in transit.
2. VPN & Secure Email – Verify use of VPNs and encrypted email services for secure communication.
3. Security & Privacy Policies – Confirm CSP has clear policies protecting data integrity and user privacy.

Check Whether Files Stored on Cloud Servers are Encrypted:

1. Ensure data at rest is encrypted by default on cloud servers.
2. Verify the encryption algorithms used are strong and industry-standard.
3. Check who holds the encryption keys (CSP or service users) to prevent unauthorized access.

Check the Data Retention Policy of Service Providers:

1. Verify the CSP's data retention policy in the SLA.
2. Check if the CSP is legally bound to disclose data to third parties or authorities.
3. Confirm the duration of data retention and procedures for complete data deletion.
4. Ensure policies cover CSP acquisition or business closure, including data transfer or extraction procedures.
5. Validate compliance with client country laws and internal corporate policies.

Check That All Users Follow Safe Internet Practices:

1. Ensure the company has a documented internet/computer usage policy for safe cloud use.
2. Verify implementation effectiveness across systems and devices; check logs for violations.
3. Policy should cover firewalls, IDS/IPS, anti-malware, and alert procedures for breaches.
4. Staff must be trained and aware of safe practices: passwords, phishing, downloads, and verifying sources.

Perform a Detailed Vulnerability Assessment:

1. Scan all cloud components (servers, apps, databases, network, storage) for vulnerabilities.
2. Analyze threats using multiple tools and methods.
3. Treat each cloud component like a physical machine during the assessment.

Try to Gain Passwords to Hijack the Cloud Service:

1. Simulate password attacks (guessing, brute force, keylogging, social engineering) on cloud apps.
2. Test network sniffing to capture sensitive info like passwords or session cookies.
3. Ensure tests are within scope and don't impact resources the company doesn't control.

Test for Virtualization Management (VM) Security:

1. Ensure host OS is updated with latest patches.
2. Check VM OS password complexity.
3. Verify unneeded services/programs are disabled.
4. Confirm individual firewalls on hosts.
5. Ensure physical security of VM hosts.
6. Implement file integrity checks.
7. Verify security of virtual machines within the VM environment.

--The End--